

Security+ 4.3 · Vulnerability Scanning

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.3 — Vulnerability Scanning**
(7:45) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Scanner: vulnerability scan (procura CVE conhecido — Nessus, Qualys, OpenVAS); SAST (static — lê o código); fuzzing (input maluco até quebrar). Vulnerability feed alimenta o scanner.

Highlights que a prova cobra

- Vuln scan: compara o sistema com o CVE conhecido
- Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra

Dicas de prova & Cenários Típicos

- 'automated tool checks for known vulnerabilities'=vulnerability scan

Cenário clássico de exame: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.3 — Vulnerability Scanning)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **CVE:** Common Vulnerabilities and Exposures: Dicionário público padronizado de vulnerabilidades de segurança da informação conhecidas.
- **CVSS:** Common Vulnerability Scoring System: Sistema numérico padronizado de pontuação de severidade de vulnerabilidades (0.0 a 10.0: Baixa, Média, Alta, Crítica).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. No sistema CVSS 3.1, uma vulnerabilidade com pontuação 9.8 é classificada como:

- A)** Baixa
- B)** Média
- C)** Alta
- D)** Crítica

2. Uma vulnerabilidade CVE-2024-1234 pontuou CVSS 3.1 como 7.5 (Alta). O que deve ser feito PRIMEIRO?

- A)** Aplicar patch imediatamente em todos os servidores
- B)** Avaliar o risco no contexto do ambiente específico
- C)** Ignorar pois não é crítica
- D)** Substituir o sistema afetado

3. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Vuln scan: compara o sistema com o CVE conhecido'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido...

4. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'automated tool checks for known vulnerabilities'=vulnerability scan'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Vuln scan: compara o sistema com o CVE conhecido'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido...

8. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "automated tool checks for known vulnerabilities'=vulnerability scan'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) D — Crítica.

✓ **Por que está certa:** No sistema CVSS 3.1 (Common Vulnerability Scoring System), a pontuação base varia de 0.0 a 10.0 e é categorizada em quatro faixas: Baixa (0.1–3.9), Média (4.0–6.9), Alta (7.0–8.9) e Crítica (9.0–10.0). Uma vulnerabilidade com pontuação 9.8 está, portanto, na faixa Crítica, indicando impacto severo e explorabilidade trivial ou quase trivial, com potencial para comprometer confidencialidade, integridade e disponibilidade de forma massiva. A CompTIA Security+ exige que o profissional saiba interpretar essas faixas para priorizar a remediação.

✗ **Por que as outras estão erradas:**

- *Baixa:* A classificação Baixa no CVSS 3.1 abrange pontuações de 0.1 a 3.9. Vulnerabilidades nessa faixa geralmente exigem condições muito específicas para exploração, têm impacto limitado ou necessitam de acesso local altamente privilegiado. Uma pontuação 9.8 está muito acima desse intervalo, indicando risco extremo, não trivial. Associar 9.8 a Baixa demonstra incompreensão total da escala.
- *Média:* A faixa Média no CVSS 3.1 vai de 4.0 a 6.9. Vulnerabilidades médias podem causar danos moderados, muitas vezes requerendo interação do usuário ou condições parciais de exploração. A pontuação 9.8 ultrapassa em muito esse limite, situando-se no topo da escala. Classificá-la como Média subestimaria gravemente a urgência de correção e contrariaria a própria definição numérica do padrão.
- *Alta:* A faixa Alta no CVSS 3.1 compreende pontuações de 7.0 a 8.9. Embora seja uma classificação séria, ainda está abaixo do patamar Crítico. Uma vulnerabilidade 9.8 é considerada Crítica porque combina, tipicamente, vetores de ataque remotos, baixa complexidade, nenhum privilégio requerido e impacto alto nos três pilares da segurança. Portanto, rotulá-la como Alta é tecnicamente incorreto segundo a especificação oficial do CVSS 3.1.

2) B — Avaliar o risco no contexto do ambiente específico.

✓ **Por que está certa:** Diante de uma vulnerabilidade com CVSS 7.5 (Alta), a primeira ação conforme as boas práticas de gestão de vulnerabilidades e o syllabus da CompTIA Security+ é avaliar o risco no contexto específico do ambiente. Isso significa considerar a criticidade do ativo afetado, a exposição da rede, a existência de controles compensatórios, a probabilidade de exploração real (por exemplo, se há exploit público ou atividade de ameaças) e o impacto nos negócios. Somente após essa análise contextual é que se decide a prioridade e a estratégia de remediação, que pode incluir patch imediato, mitigação temporária ou aceitação do risco. A pontuação CVSS é uma métrica genérica e não substitui a avaliação de risco organizacional.

✗ **Por que as outras estão erradas:**

- *Aplicar patch imediatamente em todos os servidores:* Aplicar patch imediatamente em todos os servidores sem avaliação prévia é uma abordagem temerária. Patches podem introduzir regressões, incompatibilidades ou indisponibilidade de serviços críticos, além de exigirem janelas de manutenção e testes. A gestão de mudanças e a avaliação de risco contextual são obrigatórias antes de qualquer implantação em larga escala. A pressa pode causar mais danos do que a própria vulnerabilidade, especialmente se o ativo não estiver exposto ou se houver mitigações eficazes.
- *Ignorar pois não é crítica:* Ignorar uma vulnerabilidade de pontuação 7.5 (Alta) porque não é Crítica é um erro grave de priorização. A faixa Alta indica risco significativo, com potencial de comprometer seriamente o ambiente. Mesmo que não seja 9.0+, uma vulnerabilidade Alta pode ser explorada por atacantes para obter acesso inicial, escalar privilégios ou causar negação de serviço. A decisão de não agir deve ser baseada em análise de risco documentada, não em uma classificação simplista que descarta tudo abaixo de Crítica.

- *Substituir o sistema afetado*: Substituir o sistema afetado é uma medida extrema, custosa e muitas vezes inviável a curto prazo. A substituição de sistemas envolve planejamento, orçamento, migração de dados e testes, não sendo uma resposta imediata a uma vulnerabilidade. Além disso, a vulnerabilidade pode ser corrigida com patch ou mitigação, tornando a substituição desnecessária. A primeira ação deve ser sempre a avaliação contextual para então decidir a resposta proporcional, que raramente é a troca completa do sistema.

3) D — Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Vuln scan: compara o sistema com o CVE conhecido.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Vuln scan: compara o sistema com o CVE conhecido.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.